



Informe de Remediación de Seguridad y Arquitectura

Respuesta a la Auditoría N.º 2 — Sistema de Gestión de Correspondencia Interna

PREPARADO POR	DIRIGIDO A	FECHA	REFERENCIA
SIGAL Group — Equipo ASIA Arquitectura de Soluciones de IA	FOSCAL Equipo de Ciberseguridad	2 de octubre de 2026 Versión 1.0	Auditoría de seguridad y arquitectura 31/08/2026 · 23 hallazgos (6 altos, 8 medios, 9 bajos)

Flujo STRATA `H-003` · Rama `fix/remediacion-auditoria-2` · Commit `ecd4a6f`

Este documento es la respuesta formal, punto por punto, a los hallazgos del informe «Auditoría de seguridad y arquitectura — SISMAR» del 31 de agosto de 2026. Cada remediación se entrega con código identificable, prueba automatizada y verificación ejecutada.

1. Resumen ejecutivo

El equipo ASIA de SIGAL Group recibió la auditoría de caja blanca practicada sobre SISMAR, que identificó 23 hallazgos (6 altos, 8 medios y 9 bajos) con un dictamen central: los controles de superficie existían, pero la autorización no estaba en el núcleo de la aplicación sino en la interfaz, y un usuario de menor privilegio podía leer y alterar correspondencia de otras dependencias.

Coincidimos con el dictamen y abordamos la remediación bajo la metodología STRATA v3: especificación y modelo de amenazas antes de codificar, prueba en rojo antes que código, verificación con evidencia ejecutada y seguridad transversal con poder de veto. La remediación lleva la autorización al servidor: alcance por agencia en toda lectura, pertenencia por objeto en toda mutación, sesión revocable leída de la base de datos en cada petición, archivos privados con control de acceso por objeto, política de contenido con nonce y bitácora de todas las operaciones.

A la fecha de este informe, los 23 hallazgos están remediados y verificados. Antes de cerrar, una revisión Guardian independiente sobre el cambio completo detectó 16 hallazgos adicionales, incluido uno crítico por la versión del framework; 13 quedaron también cerrados, uno permanece como riesgo residual documentado y dos requieren una decisión conjunta con FOSCAL sobre el historial del repositorio. El despliegue a pre-producción se mantuvo bloqueado durante toda la remediación y sigue condicionado a esa decisión.

23/23 HALLAZGOS REMEDIADOS	6/6 ALTOS	253 TESTS EN VERDE	0 VULNERABILIDADES (npm audit)	16 HALLAZGOS ADICIONALES PROPIOS	13 DE ELLOS CERRADOS
---	---------------------	------------------------------	---	---	--------------------------------

2. Alcance y método de trabajo

El alcance cubre los 23 hallazgos del informe (A-01 a A-06, M-01 a M-08 y B-01 a B-09). Quedan fuera, como declara el propio auditor, el cifrado en reposo, las copias de seguridad y la revisión de la infraestructura del servidor.

Secuencia STRATA v3 aplicada

- Especificación (Gate SDD).** Spec del Flujo H-003 con 14 criterios de aceptación binarios, modelo de amenazas con 22 casos de abuso (AC-001...AC-022), 16 contratos (C-001...C-016) y 30 escenarios BDD (S-001...S-030).
- Construcción (Gate TDD).** Cada contrato se implementó con pruebas que pasaron de rojo a verde; la suite creció de 55 a 253 pruebas en 30 archivos, con cobertura del 81 % en la capa de lógica y seguridad.
- Verificación (Gate BDD).** Compilación de producción, auditoría de dependencias, migración sobre una base con datos y smoke de extremo a extremo en navegador con un usuario de cada rol y dos agencias distintas.
- Revisión Guardian independiente.** Un revisor de seguridad independiente del equipo que implementó auditó el cambio completo con veto; sus hallazgos se verificaron uno a uno y se corrigieron con el mismo rigor (sección 6).

Trazabilidad: [specs/H-003-remediacion-auditoria-2/](#) (especificación, modelo de amenazas, contratos y escenarios BDD) y la suite de pruebas en [tests/security/](#).

3. Estado por hallazgo

Convención: RESUELTO = remediado y verificado con evidencia ejecutada. Los riesgos residuales asociados se detallan en la sección 8.

ID	SEV.	REMEDIACIÓN	ESTADO
A-01	ALTA	Alcance por agencia (tenencia) en todas las lecturas: dashboard, reportes, correspondencia, planillas, recorridos	RESUELTO
A-02	ALTA	Edición, aprobación y devolución verifican permiso y pertenencia del registro; IDs ajenos → 403	RESUELTO
A-03	ALTA	Ciclo de planillas con permiso planillas.gestionar y dueño; salientes compartidas solo con alcance global	RESUELTO
A-04	ALTA	Las 15 acciones de catálogos exigen rol ADMIN leído de la base de datos	RESUELTO
A-05	ALTA	Sesión en base de datos, revocable; rol fresco por petición; sin renovación indefinida	RESUELTO
A-06	ALTA	Archivos fuera de public/, servidos solo por API con sesión viva y control de acceso por objeto	RESUELTO
M-01	MEDIA	Permiso explícito en cada página (incluidas las 11 de administración); «Acceso denegado» visible	RESUELTO
M-02	MEDIA	Seed no destructivo, sin contraseñas fijas, bloqueado en producción	RESUELTO
M-03	MEDIA	Validación del contenido real del archivo (magic bytes); .gif retirado	RESUELTO
M-04	MEDIA	Límite por usuario y por IP; bloqueo persistente de cuenta en BD (Redis si se escala: riesgo residual R-020)	RESUELTO
M-05	MEDIA	Redirecciones solo a hosts de una lista permitida (ALLOWED_HOSTS)	RESUELTO
M-06	MEDIA	CSP con nonce por petición (sin unsafe-inline en scripts); colores de marca validados dos veces	RESUELTO
M-07	MEDIA	Bitácora AuditLog de todas las operaciones con usuario, acción, entidad e IP; autoría en registros	RESUELTO
M-08	MEDIA	Tiempo de respuesta constante en el login y bloqueo persistente tras 10 fallos	RESUELTO
B-01	BAJA	Cookie de sesión con los mismos atributos seguros en todas las operaciones, incluido el middleware	RESUELTO
B-02	BAJA	Roles, tipos y estados como enumeraciones de base de datos (migración sin pérdida)	RESUELTO
B-03	BAJA	Transacciones y actualizaciones condicionadas al estado; índices en columnas de filtro	RESUELTO
B-04	BAJA	Tests de autorización por rol y comportamiento; guard esperado por acción; guard en cada página	RESUELTO
B-05	BAJA	Correo validado en usuarios; módulo de notificaciones (envío real pendiente de SMTP: R-021)	RESUELTO
B-06	BAJA	Esquema de validación completo en la edición de correspondencia; topes de anexos	RESUELTO
B-07	BAJA	README real y runbook de operación versionado sin secretos	RESUELTO
B-08	BAJA	Dependencia cookie eliminada; módulo planillas renombrado	RESUELTO

ID	SEV.	REMEDIACIÓN	ESTADO
B-09	BAJA	Un usuario AGENCIA exige agencia asignada (formulario, servidor y alcance vacío si falta)	RESUELTO

4. Cambios estructurales

Las remediaciones no se aplicaron como parches aislados: descansan sobre piezas comunes que gobiernan toda la aplicación.

PIEZA	QUÉ GARANTIZA
Contexto de autenticación fresco	El rol y la agencia se leen de la base de datos en cada petición; la sesión vive en una tabla propia y es revocable (cierre de sesión, cambio de rol o contraseña, eliminación del usuario). Expiración absoluta de 24 horas.
Módulo de tenencia	Un único lugar decide el alcance de cada rol y construye los filtros de todas las consultas; ninguna página ni acción arma filtros por su cuenta. Un rol sin alcance definido no ve nada.
Denegación explícita	Las acciones devuelven un error 403 claro; las páginas muestran «Acceso denegado»; los objetos ajenos responden 404 para no revelar su existencia. Todo intento queda en la bitácora.
Bitácora de auditoría	Tabla de solo inserción con usuario, acción, entidad, detalle y dirección IP para inicio y cierre de sesión, accesos denegados y toda operación de negocio y administración.
Archivos privados	Almacenamiento fuera de la carpeta pública, entrega únicamente por API con sesión viva, control de acceso por el objeto que referencia el archivo y validación del contenido real.
Catálogo único de permisos	Dos permisos nuevos (gestionar planillas y recibir correspondencia) y un script idempotente de sincronización para bases ya desplegadas.
Integridad en la base de datos	Enumeraciones para roles, tipos y estados, índices en columnas de filtro, transacciones y un índice único que impide dos recorridos activos.

5. Detalle de las soluciones aplicadas

Se describe, para cada hallazgo, la solución implementada en lenguaje no técnico y la evidencia con que se verificó.

A-01 — Sin aislamiento de datos por agencia en lectura

Se creó un módulo único de tenencia que decide el alcance de cada rol: ADMIN y MENSAJERO ven la operación completa; un usuario AGENCIA ve únicamente su agencia; y una cuenta AGENCIA sin agencia asignada no ve nada. Ese módulo construye los filtros de todas las consultas del dashboard, los reportes (incluidos los contadores y la lista de agencias del filtro), la correspondencia entrante y saliente, las planillas, el detalle de planilla, los recorridos y «Mis Planillas». Un identificador de agencia ajena forzado en la URL se ignora.

Evidencia: Pruebas unitarias del módulo de tenencia y prueba de extremo a extremo con dos agencias: cada usuario ve solo sus registros y una planilla ajena responde 404.

A-02 — Edición y gestión de correspondencia ajena por identificador

La acción de completar o editar una pieza ahora carga primero el registro, exige el permiso según el tipo real del registro (no el que envía el navegador), verifica que pertenezca a la agencia del usuario e impide que una agencia reasigne una pieza a otra. Aprobar y devolver exigen el permiso específico de recepción, que el mensajero no tiene,

además de la pertenencia y de que la pieza esté pendiente dentro de una planilla cerrada en un recorrido activo. Se registra quién recibió cada pieza.

Evidencia: Pruebas de comportamiento por rol (agencia ajena, tipo manipulado, mensajero) y aprobación real de una pieza propia en la prueba de extremo a extremo.

A-03 — Ciclo de vida de planillas sin permiso ni dueño

Cerrar, reabrir, retirar piezas y subir la firma exigen el nuevo permiso de gestión de planillas y la pertenencia de la planilla; procesarla exige el permiso de recepción y la pertenencia. Como las planillas salientes agrupan piezas de todas las agencias, su gestión y su soporte firmado quedan reservados al alcance global, aunque una agencia tenga piezas dentro. Las transiciones de estado son atómicas.

Evidencia: Pruebas de comportamiento para cada acción y generación de una planilla saliente desde la interfaz en la prueba de extremo a extremo.

A-04 — Catálogos modificables por cualquier usuario autenticado

Las quince acciones de catálogos (ciudades, empresas de mensajería, agencias, centros de costo y sedes) exigen ahora el rol de administrador leído de la base de datos en el momento de la petición. Se eliminó la copia duplicada del control de administrador que existía en otro módulo.

Evidencia: Prueba de comportamiento: un usuario de agencia o un mensajero con todos los permisos de la matriz reciben un 403 explícito y no se crea nada; prueba estática que falla si vuelve a usarse un control genérico de sesión.

A-05 — Sesión no revocable con rol congelado

La sesión vive ahora en la base de datos: el token de la cookie solo la identifica, y en cada petición el servidor comprueba que siga viva y lee el rol y la agencia actuales del usuario. Cerrar sesión la revoca en el servidor; cambiar el rol, la agencia o la contraseña de un usuario revoca todas sus sesiones; eliminarlo las elimina. La expiración es absoluta (24 horas), sin renovación indefinida. Una cookie cuya sesión ya no sirve se borra automáticamente y el usuario vuelve al inicio de sesión con un aviso.

Evidencia: Pruebas unitarias del almacén de sesiones y del control de acceso; prueba de extremo a extremo: una sesión revocada en la base de datos deja de servir en la petición siguiente.

A-06 — Archivos subidos accesibles sin autenticación

Los archivos se guardan fuera de la carpeta pública (en un directorio privado configurable) y se entregan únicamente a través de la API, que exige sesión viva y comprueba que el archivo esté referenciado por una pieza, planilla o logotipo que el usuario puede ver. Los nombres los genera el servidor; el directorio público antiguo responde 404 aunque conserve archivos, y un script traslada los archivos existentes al nuevo directorio.

Evidencia: Pruebas de la API (401 sin sesión, 403 ajeno, 404 huérfano, 400 ante intentos de recorrer directorios) y verificación de extremo a extremo con dos agencias.

M-01 — Permisos granulares no aplicados en las páginas

Cada página de negocio exige su permiso al inicio y, si falta, muestra una pantalla de «Acceso denegado» en lugar de redirigir en silencio; el intento queda en la bitácora. Tras la revisión interna se añadió además el control propio a cada una de las once páginas de administración, porque los layouts del framework pueden omitirse en ciertas peticiones del cliente.

Evidencia: Prueba estática que exige un control propio en todas las páginas antes de consultar datos, y prueba de concepto ejecutada contra el servidor local.

M-02 — Seed destructivo con contraseña por defecto

El script de datos iniciales ya no borra nada: crea o actualiza catálogos y permisos de forma idempotente, solo crea usuarios si la tabla está vacía, toma las contraseñas del entorno o genera contraseñas fuertes que muestra una sola vez, y se niega a ejecutarse en producción salvo autorización explícita.

Evidencia: Prueba estática del script y ejecución sobre la base de datos local.

M-03 — Validación del tipo de archivo basada en lo que declara el navegador

Además del tipo declarado, la extensión y el tamaño, ahora se inspeccionan los primeros bytes del archivo para confirmar que realmente es un PDF, PNG o JPG. Un archivo HTML disfrazado de imagen se rechaza. El formato .gif dejó de servirse.

Evidencia: Pruebas unitarias con archivos reales en disco.

M-04 — Límite de intentos solo por usuario y en memoria

El límite de intentos se aplica por usuario y también por dirección IP del cliente real. El bloqueo de cuenta se guarda en la base de datos, por lo que sobrevive a reinicios y a varias instancias. El contador de ventana sigue en memoria, adecuado para la instancia única actual; queda documentado migrarlo a un almacén compartido si la aplicación escala (riesgo residual R-020).

Evidencia: Pruebas unitarias de ambos límites y de la extracción de la IP del cliente.

M-05 — Redirecciones construidas con la cabecera Host

Las redirecciones solo se construyen hacia hosts de una lista permitida configurada en el servidor; cualquier otro valor se sustituye por el primer host permitido y el protocolo se restringe a http o https.

Evidencia: Pruebas unitarias y del middleware con una cabecera Host hostil.

M-06 — CSP con unsafe-inline y colores de marca sin validar

La política de seguridad de contenido se genera por petición con un valor aleatorio (nonce) y «strict-dynamic», eliminando unsafe-inline para scripts; toda la aplicación se renderiza dinámicamente para que el nonce se aplique. Los colores de marca se validan contra el formato HSL al guardarse y de nuevo al inyectarse. Se conserva unsafe-inline solo para estilos, requisito del framework (riesgo residual R-022).

Evidencia: Pruebas de la política y de la validación; en el navegador, cero violaciones y todos los scripts con nonce.

M-07 — Sin bitácora ni autoría de operaciones

Se añadió una bitácora de solo inserción que registra inicio y cierre de sesión, accesos denegados, descargas denegadas y todas las operaciones de negocio y administración, con usuario, acción, entidad, detalle (incluidos los valores previos en las ediciones) y dirección IP. Los registros de correspondencia y planillas guardan quién los creó, modificó o recibió.

Evidencia: Pruebas unitarias y verificación en la base de datos durante la prueba de extremo a extremo.

M-08 — Oráculo de tiempo en el login y sin bloqueo de cuenta

El inicio de sesión tarda lo mismo exista o no el usuario, porque siempre se ejecuta una comparación de contraseña. Diez fallos consecutivos bloquean la cuenta durante quince minutos de forma persistente, con el mismo mensaje genérico. Las contraseñas con un coste de cifrado heredado menor se re-cifran al coste actual la siguiente vez que el usuario entra.

Evidencia: Pruebas de comportamiento del inicio de sesión con base de datos simulada.

B-01 — Cookie emitida por el middleware sin path

Los atributos de la cookie se definen en un único lugar compartido por todas las operaciones; el middleware ya no emite cookies salvo para limpiarlas, y lo hace con los mismos atributos.

Evidencia: Pruebas del middleware y del cierre de sesión.

B-02 — Roles y estados almacenados como texto libre

Roles, tipos y estados pasaron a enumeraciones de la base de datos mediante una migración escrita a mano que conserva los datos existentes y aborta con un mensaje claro si encontrara valores fuera de dominio.

Evidencia: Migración aplicada sobre una base con datos; roles y permisos conservados.

B-03 — Sin transacciones ni índices en flujos concurrentes

La generación de planillas se ejecuta en una transacción con actualizaciones condicionadas al estado, de modo que dos clics simultáneos no duplican ni pierden piezas; aprobar, devolver, cerrar, reabrir y procesar también son atómicos, y la base de datos impide dos recorridos activos a la vez. Se añadieron índices en las columnas de filtro.

Evidencia: Pruebas de comportamiento y migraciones aplicadas.

B-04 — Tests que solo comprobaban la presencia de un control

La prueba estática exige ahora el control concreto esperado por cada acción, ignora comentarios y falla si aparece una acción nueva sin declarar. Se añadieron pruebas de comportamiento por rol que reproducen los casos de abuso del modelo de amenazas, pruebas del inicio de sesión, de la revocación de sesiones y de los controles de página.

Evidencia: Suite de 253 pruebas en 30 archivos.

B-05 — Notificaciones por consola y usuarios sin correo

El correo electrónico es ahora un dato validado del usuario (formulario y listado) y los avisos salen por un módulo único de notificaciones que no escribe datos personales en los registros de producción. El envío real requiere las credenciales SMTP del cliente (riesgo residual R-021); la interfaz lo indica.

Evidencia: Pruebas de esquema; módulo listo para conectar un proveedor.

B-06 — Edición de correspondencia sin esquema de validación

La edición valida ahora cada campo con un esquema completo (longitudes, importancia, agencia) y limita el tamaño y el número de identificadores de anexo. Solo se edita una pieza pendiente y fuera de planilla, protegiendo la cadena de custodia. Se corrigió además un error funcional: al editar una saliente se perdía el destinatario.

Evidencia: Pruebas de esquema y de comportamiento.

B-07 — README de plantilla y operación fuera del repositorio

El repositorio incluye un README real y un runbook de operación versionado que describe instalación, actualización, variables, bitácora, respaldos e incidentes sin exponer secretos, direcciones ni dominios reales.

Evidencia: Revisión documental.

B-08 — Dependencia sin uso y módulo mal nombrado

Se eliminó la dependencia sin uso y se renombró el módulo de planillas; una prueba lo verifica.

Evidencia: Prueba de dependencias y compilación.

B-09 — Usuario AGENCIA sin agencia asignada

El formulario y el servidor exigen una agencia para el rol AGENCIA y comprueban que exista; si por algún motivo faltara, el alcance del usuario es vacío en toda la aplicación.

Evidencia: Pruebas de esquema y de tenencia.

6. Revisión Guardian independiente

Antes de declarar cerrado el trabajo, un revisor de seguridad independiente del equipo que implementó la remediación analizó el cambio completo con capacidad de veto. Devolvió 16 hallazgos adicionales. Los tratamos con el mismo método que los del auditor: verificación uno a uno, prueba en rojo, corrección y verificación. El veto se levantó tras una segunda revisión, con dos decisiones separadas: el cierre técnico queda autorizado; el despliegue y la publicación al repositorio del cliente quedan condicionados a la decisión conjunta sobre R-029.

ID	SEV.	HALLAZGO	RESOLUCIÓN	ESTADO
R-027	CRÍTICA	Versión del framework (Next.js 16.0.8) con avisos de seguridad publicados y dependencias transitivas vulnerables.	Actualizado a 16.3.8 con versión fijada; dependencias corregidas; auditoría de dependencias en cero.	CERRADO
R-028	ALTA	Las páginas de administración confiaban solo en el layout, que puede omitirse en peticiones RSC del cliente.	Control propio en las 11 páginas, prueba estática y prueba de concepto ejecutada.	CERRADO
R-029	ALTA	Cuatro PDF cargados en pruebas del piloto quedaron versionados en el repositorio desde el inicio; dos tienen apariencia de facturas personales.	Retirados del control de versiones y del índice; persisten en el historial. Requiere decisión conjunta (ver §8).	DECISIÓN
R-030	MEDIA	El soporte firmado de una planilla saliente era legible por cualquier agencia con una pieza en ella.	Acceso solo con alcance global; vista previa oculta a las agencias.	CERRADO
R-031	MEDIA	Una agencia con permiso de gestión delegado podía cerrar o firmar una saliente compartida.	La gestión de salientes exige alcance global.	CERRADO
R-032	MEDIA	Contraseñas con coste de cifrado heredado permitían deducir qué cuentas existen por el tiempo de respuesta.	Re-cifrado automático al iniciar sesión; verificación pendiente en el servidor para cuentas que no hayan vuelto a entrar.	ABIERTO
R-033	BAJA	La edición consultaba la base de datos antes de autenticar.	Autenticación primero.	CERRADO
R-034	BAJA	Edición posible en cualquier estado y sin valores previos en la bitácora.	Solo piezas pendientes sin planilla; valores previos registrados.	CERRADO
R-035	BAJA	Conteos globales de planillas con solo sesión.	Permiso y alcance aplicados.	CERRADO
R-036	BAJA	Falsa cobertura en algunas pruebas estáticas; faltaban pruebas de páginas, login y revocación.	Pruebas añadidas y endurecidas.	CERRADO
R-037	BAJA	Inyección de fórmulas en la exportación CSV.	Celdas neutralizadas.	CERRADO
R-038	BAJA	Un atacante puede mantener bloqueada una cuenta conocida provocando fallos de login.	Riesgo residual documentado: límite por IP, renombrar la cuenta administrativa, alertas.	RESIDUAL
R-039	BAJA	El seed podía generar una contraseña no mostrada si la del entorno era inválida.	El seed aborta con mensaje claro.	CERRADO

ID	SEV.	HALLAZGO	RESOLUCIÓN	ESTADO
R-040	BAJA	Alta de correspondencia sin topes de longitud ni de anexos.	Topes aplicados.	CERRADO
R-041	BAJA	Condiciones de carrera en aprobaciones y creación de recorridos.	Actualizaciones atómicas, transacción e índice único.	CERRADO
R-042...R-046	INFO	Menores: validación de la URL del logotipo, ruta pública por igualdad exacta, usuario tecleado en la bitácora, versión exacta del framework, transiciones de planilla atómicas.	Corregidos.	CERRADO
R-047	INFO	El espejo interno de SIGAL Group conserva el mismo historial que el repositorio del cliente.	Se incluye en la decisión de R-029.	DECISIÓN

Lección incorporada al método de SIGAL Group: autenticar no es autorizar. El alcance de cada rol y la pertenencia de cada objeto deben decidirse en el servidor y probarse por comportamiento; los layouts del framework no son una frontera de seguridad; y la auditoría de dependencias forma parte de la compuerta de despliegue. Estos puntos se añadieron al checklist Guardian que SIGAL Group aplica a todos sus proyectos.

7. Verificación (Gate BDD)

- **253 pruebas automatizadas en verde** (30 archivos): tenencia, pertenencia por objeto, sesión revocable, control de acceso a archivos y validación de contenido, inicio de sesión endurecido, política de contenido, middleware, controles de página, revocación de sesiones, exportación CSV y seed seguro. Cobertura del 81 % en la capa de lógica y seguridad.
- **Compilación de producción sin errores** con TypeScript estricto y Next.js 16.3.8; auditoría de dependencias sin vulnerabilidades.
- **Migraciones aplicadas sobre una base con datos** sin pérdida: roles, permisos y registros conservados; las conversiones a enumeraciones abortan con un mensaje claro ante valores fuera de dominio.
- **Smoke de extremo a extremo** sobre la compilación de producción con PostgreSQL y un usuario de cada rol: la agencia 1 no ve ni alcanza datos de la agencia 2 (reportes, planillas, archivos); la agencia 2 aprueba su pieza y queda registrado quién la recibió; una sesión revocada deja de servir en la petición siguiente; el administrador ve la operación completa; cero violaciones de la política de contenido en el navegador.
- **Prueba de concepto del control por página:** una petición que omite los layouts recibe «Acceso denegado» para una agencia y la salida de sesión para una cookie revocada, mientras que el administrador sí recibe los datos.
- **Cabeceras y códigos:** CSP con nonce y HSTS presentes; sin sesión, las páginas redirigen al inicio de sesión, la API de archivos responde 401 y el directorio público antiguo responde 404.

Hallazgos propios durante la verificación (resueltos antes del cierre)

1. Un bucle de redirecciones al revocar una sesión: el middleware aceptaba un token bien firmado mientras el servidor detectaba la sesión revocada. Se añadió una ruta que borra la cookie inválida y envía al inicio de sesión con aviso. Solo lo detectó la prueba en navegador, no las pruebas unitarias.
2. El nonce de la política de contenido no se aplicaba en páginas prerenderizadas ni en el script de tema; toda la aplicación pasó a renderizarse dinámicamente y el script recibe el nonce.

- Un error funcional preexistente: al editar una pieza saliente se borraba el destinatario. Quedó corregido con el nuevo esquema de validación.

8. Riesgos residuales y decisiones solicitadas a FOSCAL

Los siguientes puntos no son vulnerabilidades abiertas sino riesgos documentados que requieren aceptación formal o una decisión conjunta.

CÓDIGO	RIESGO	MITIGACIÓN ACTUAL	SE SOLICITA
R-020	Contador de límite de intentos en memoria del proceso (instancia única).	El bloqueo de cuenta persiste en base de datos. Migrar a Redis solo si se escala a varias instancias.	Aceptación
R-021	El envío real de correo depende de credenciales SMTP del cliente.	Módulo listo para conectar un proveedor.	Entregar credenciales SMTP
R-022	La política de contenido conserva unsafe-inline para estilos.	Requisito del framework; colores validados en entrada y salida; ningún estilo depende de entrada de usuario.	Aceptación
R-029	Archivos de prueba en el historial de git (incluidas posibles facturas personales).	Ya no se versionan. Purgar el historial exige coordinación y reescritura de ramas compartidas.	Acordar purga o aceptación; evaluar Ley 1581
R-032	Cuentas con contraseña de coste heredado que no vuelvan a iniciar sesión.	Verificar en el servidor y rotar las que aparezcan.	Verificación en despliegue
R-038	Bloqueo de cuenta usable para impedir el acceso a un usuario conocido.	Límite por IP, renombrar la cuenta administrativa en el despliegue, alertar ante bloqueos.	Aceptación

Sobre R-029 (archivos en el historial del repositorio)

Durante la revisión interna se detectó que cuatro archivos PDF cargados durante las pruebas del piloto quedaron versionados en el repositorio desde su primer commit; dos de ellos tienen apariencia de facturas personales de un tercero. Ya no forman parte del control de versiones, el directorio queda excluido y una prueba automatizada impide que vuelvan a entrar. Sin embargo, permanecen en el historial de todas las copias del repositorio, incluida la del cliente. SIGAL Group recomienda acordar con FOSCAL la purga del historial de forma coordinada en todos los repositorios y evaluar, con su área de protección de datos, si procede alguna actuación conforme a la Ley 1581 de 2012. Hasta esa decisión, la publicación de esta versión al repositorio del cliente permanece en espera.

9. Pasos para el despliegue en pre-producción

- Añadir al entorno del servidor las variables `ALLOWED_HOSTS` (dominio público) y `UPLOADS_DIR` (directorio privado de archivos, fuera de la carpeta pública).
- Aplicar las migraciones (`prisma migrate deploy`) y regenerar el cliente de datos.
- Sincronizar el catálogo de permisos (`prisma/sync-permissions.ts`) y trasladar los archivos existentes al directorio privado (`prisma/migrate-uploads.ts`).
- Compilar y reiniciar el proceso de la aplicación.
- Verificar cabeceras y códigos de respuesta (CSP con nonce, HSTS, 307 al inicio de sesión, 401 en la API de archivos, 404 en el directorio público antiguo) y ejecutar la auditoría de dependencias.

6. Comprobar que ninguna cuenta conserva una contraseña con coste de cifrado heredado y rotar las que aparezcan.
7. Avisar a los usuarios: todas las sesiones anteriores quedan invalidadas y deberán iniciar sesión de nuevo.

El detalle operativo, sin secretos, está en `docs/OPERACION.md` y en el Manual de Implementación en Cliente.

10. Recomendación y cierre

SIGAL Group considera cerrada técnicamente la remediación de la Auditoría N.º 2: los 23 hallazgos están resueltos y verificados, y los hallazgos adicionales de la revisión independiente se corrigieron o quedaron documentados como riesgos residuales. El despliegue a pre-producción queda recomendado una vez FOSCAL se pronuncie sobre los puntos de la sección 8, en particular la decisión conjunta sobre R-029, y se ejecuten los pasos de la sección 9.

Quedamos atentos a la revisión del equipo de Ciberseguridad de FOSCAL para el cierre formal. Un pentest autenticado con un usuario de rol AGENCIA, como el propio auditor sugiere, es la mejor forma de confirmar de manera independiente lo aquí expuesto; el equipo ASIA está disponible para acompañarlo.

SIGAL Group — Equipo ASIA

Arquitectura de Soluciones de Inteligencia Artificial · Metodología STRATA v3

BY SIGAL GROUP

Anexo A. Inventario de evidencia

ARTEFACTO	CONTENIDO
specs/H-003-remediacion-auditoria-2/	Spec STR-A09, threat model STR-A13 (AC-001...AC-022), contratos C-001...C-016, escenarios BDD S-001...S-030.
tests/security/ (30 archivos)	253 pruebas: tenencia, autorización por rol, sesión, archivos, login, CSP, middleware, páginas, revocación, CSV, seed, esquemas.
tests/e2e/rsc-admin-bypass.poc.ts	Prueba de concepto manual del control propio por página frente a peticiones que omiten los layouts.
prisma/migrations/202610011200_00_..., 20261001133000_...	Migraciones de enumeraciones, sesiones, bitácora, bloqueo de cuenta, índices y recorrido único, escritas a mano para conservar los datos.
docs/OPERACION.md • README.md	Runbook de operación y guía del repositorio, sin secretos ni datos de infraestructura.
docs/manuales/	Manual del Usuario, Manual Técnico y Manual de Implementación en Cliente (Word y fuente Markdown).

Anexo B. Glosario

Tenencia (tenancy). Regla que determina qué datos puede ver y modificar cada rol según su agencia; aquí se aplica en el servidor a toda consulta.

IDOR. Acceso a un objeto ajeno manipulando su identificador (por ejemplo, el número de una planilla); se neutraliza verificando la pertenencia en cada operación.

Sesión revocable. Sesión registrada en la base de datos que puede invalidarse de inmediato desde el servidor, a diferencia de un token que vale hasta su caducidad.

Magic bytes. Primeros bytes que identifican el tipo real de un archivo; permiten rechazar un archivo malicioso disfrazado con una extensión permitida.

CSP con nonce. Política de seguridad de contenido que solo permite ejecutar los scripts marcados con un valor aleatorio generado en cada petición.

RSC. Componentes de servidor de React; una petición de este tipo puede pedir solo parte de una página, por lo que cada página debe aplicar su propio control de acceso.

Bitácora (AuditLog). Registro inalterable de quién hizo qué, cuándo y desde dónde.